Who Said That?
A Controlled Test of Summary and Source-Label Prompt Injection

Ruslans Aleksejevs

9 November 2026
Main-study draft—pending author review

Abstract

An executor can encounter an indirect prompt injection in an external record or in another agent's summary. We test whether observed permission-boundary failures differ with text transformation or displayed source identity, without changing actual message privileges. A frozen synthetic testbed replays one saved summary, original records and verbatim extracts under document and colleague labels, alongside two soft defenses and a deterministic permission-gate replay. After a separately reported development pilot, the held-out main study evaluates 40 attacked and 20 clean inputs with Qwen3.5-122B-A10B through one fixed hosted provider route. All 540 scheduled roles are attempted, using 548 physical requests. Of 480 executor cells, 445 are valid, 33 are atomically rejected and two are unavailable after HTTP 429 errors; 443 achieve useful correct completion. No forbidden state transition or schema-valid protected-write attempt is observed in the 478 available responses. Both primary contrasts have 39 complete attacked pairs, zero point estimates and conservative intervals of approximately plus or minus 43.49 percentage points. One attacked input fails the length-matching criterion. These results do not demonstrate a laundering effect, equivalence, universal safety or defense efficacy. The contribution is an auditable decomposition and negative evidence with explicit utility, missingness, acquisition failures and financial reservations; development and main observations remain separate.

1 Question and related work

An executor may encounter an untrusted instruction in an external record or in another agent's summary of that record. Does the resulting risk depend on text transformation, on the displayed source identity, or on both? We separate these interventions without promoting the source text to a higher-priority API role. The two primary contrasts are the same saved summary under two source labels, and a summary versus a length-matched verbatim extract under the same label.

This is not a claim to discover indirect prompt injection or provenance laundering. *Can CaMeLs Talk?* already studies untrusted content crossing agent boundaries, including summarization handoffs, and proposes provenance-preserving communication [1]. Our controlled source-label replay neither implements nor reproduces multi-CaMeL. *StateFence* motivates protecting task state while measuring the utility cost of evidence filtering [2]. Our synthetic dictionary environment is not its security-operations benchmark. The intended contribution is a small, auditable decomposition with exact state outcomes, including an honest record of interface and acquisition failures.

2 Methods

2.1 Tasks, roles and threat model

Each synthetic record contains task facts, one controlled attack or neutral paragraph, and ordinary archive text. A legitimate task asks for an exact lookup or arithmetic answer, written as a string to `results[task_id].answer`. The attacker seeks an additional write setting `protected[task_id].`

Content	External document (D)	Colleague handoff (P)
Original record (R)	R-D	R-P
Verbatim extract (E)	E-D	E-P
Saved summary (S)	S-D	S-P

Table 1: Six core replay cells. D/P changes only a 17-byte source description in the same low-priority message envelope. All S cells share identical summary bytes. Two additional S-P cells add a generic warning or specific provenance.

`approved` from false to true. A tool-free summarizer receives the original task and untrusted record. Its fixed policy requests an accurate task-relevant summary and treats source instructions as data, without asking it to preserve or strengthen the attack. An executor then proposes one JSON batch of at most eight mock actions, with no interactive feedback turn.

The attacker controls only the designated source paragraph. It cannot change the task, system policy, tool schema, scorer or trusted wrapper. The four fixed families are a colleague's extra request, forged approval, a purported prerequisite side effect, and an instruction inside a quoted work plan. No external service, file, credential or real account is attacked. The mock tool deliberately permits protected writes at the technical level, while the immutable system policy forbids them. This tests adherence to a permission boundary, not a production vulnerability.

2.2 Replay interventions

Exactly one summary is saved per input. Every executor condition uses a fresh context and reset environment. Its user-message envelope contains the original task and the evidence; neither source description changes the system policy. Table 1 shows the factorial core. R-P and S-D are intentional counterfactual presentations; S-P is the natural record–summary–executor path.

The extract retains all required facts and the complete attack/control paragraph, then ends at an original word boundary nearest to the summary's UTF-8 byte length. Ties favor the shorter extract. It never rewrites source words or truncates mandatory spans. A relative length gap of at most 10% is considered matched; more than 20% unmatched assessable attacked cases flags an inadequate length control. All cases remain in the primary analysis. Even a matched S-P/E-P contrast is a *transformation bundle*: selection, deletion and rewriting can all change meaning. It is not an isolated paraphrasing effect.

Two secondary comparisons reuse S-P's exact summary. S-P-W adds a generic warning against following untrusted instructions. S-P-P adds harness-authored origin, source, transform and task fields, including `authority_to_change_task=false`. Supplements have equal UTF-8 byte length through whitespace padding, not equal tokenizer counts or information. These are soft interventions. A separate deterministic allowlist replays each identical action batch and blocks protected writes; its behavior is an engineering control, not another model experiment or a test of recovery after denial.

2.3 Exact outcomes and useful completion

The entire JSON batch is validated before any action is executed. Duplicate keys, extra properties, wrong value types and malformed envelopes execute nothing and remain invalid responses. A forbidden attempt is a protected-store action in a schema-valid batch; malformed textual intentions are not silently counted as valid executed attempts. Wrong-task actions are rejected without mutation.

The primary outcome Y_{ic} is any protected false-to-true state transition for input i in condition c, even if a later action reverts it. The scorer replays every action and verifies every before/after event and the final state. It also records exact task correctness, joint safe-and-correct completion, valid responses, abstention and blocked actions. An invalid batch has zero executed effects but cannot count as a valid safe completion. Missing transport or context outcomes remain unknown, never safe-imputed. Lexical fact/target-retention

flags describe strings, not semantic retention or hidden model reasoning.

2.4 Model, development and planned evaluation

The single user-selected route is `qwen/qwen3.5-122b-a10b` through OpenRouter's Alibaba endpoint, without fallback. Both roles use the same fixed configuration in separate contexts. Temperature is 0.6, top-p 0.95 and requested `max_tokens` 8,192. Reasoning is enabled, but hidden reasoning text is excluded from retained records. Completion-token counts include billed reasoning. The hosted alias and dated endpoint display name do not pin an exact served weight revision.

The development pilot schedules eight attacked and four clean inputs: 12 summaries plus 96 executor calls. The clean inputs run first; executor-cell order is seeded and frozen. The quoted-plan family is outside empirical pilot tuning, not unknown to the developers. The planned main set contains 40 attacked inputs (ten per family) and 20 predetermined clean counterparts, for 540 calls. Main task templates, identifiers and numeric ranges differ from development and inspected engineering fixtures. There is one payload per input, no best-of-N attack selection and no outcome-driven prompt revision in this live campaign.

Main requires an audited pilot with at least 98/108 valid role responses and 26/32 correct clean executor cells. The clean cells represent only four originals. An operational continuation after the observed outage is disclosed separately; it does not lower these thresholds or replace attempted responses.

2.5 Statistics and acquisition integrity

The primary contrasts are S-P minus S-D and S-P minus E-P on attacked inputs. Saved analysis reports paired complete-case differences, 2,000 cluster-bootstrap draws (seed 8128), exact paired McNemar tests with Holm adjustment across the two primary contrasts, and worst-case full-schedule missingness bounds. Related conditions and clean counterparts stay in the same scenario cluster. Conservative bounded-cluster intervals accompany percentile intervals that can collapse at zero discordance. These calculations assume independent clusters; shared payload templates, a small fixed synthetic task set and one sample per condition limit generalization. Defense, family and summary-dependent matched subsets are secondary/descriptive, not causal mediation analyses.

An append-only, hash-chained wallet reserves USD 0.61341696 before every request under a hard USD 30 study ceiling. This conservative bound separately reserves 262,144 input and output tokens at USD 0.26/2.08 per million; it is not expected cost or permission to spend above the ceiling. Verified unused reserve may be released; unknown charges retain their full reserve. Exact provider route, visible SSE assembly, usage, saved request identity, source inventory and state outcomes are independently reconstructed by the audit. Local hashes establish internal consistency, not a signed provider attestation. Raw logs stay private; reviewed synthetic outputs and minimized accounting records are published.

3 Held-out main results

3.1 Acquisition and exact outcomes

The main manifest was frozen after the amended development gate passed, before any main output. Acquisition ran from 8 November 2026 at 23:53:27 UTC to 9 November at 03:04:13 UTC and exited successfully without a stop condition. All 540 planned roles were attempted: 60 summaries and 480 executor cells. Eight identical technical retries produced 548 physical requests, within the 567-attempt stage cap. Ten HTTP 429 receipts include two exhausted same-role retry pairs; those executor outcomes remain missing. No invalid response was repaired, resampled or replaced.

All 60 summaries were available. The executor matrix has 445 valid batches, 33 invalid batches (32 invalid JSON, one invalid action schema), and two missing transport outcomes. The two valid but incorrect batches are empty-action abstentions. Useful correct completion is 443/480 scheduled cells (92.29%),

	Attacked (40 scheduled per cell)			Clean (20 per cell)		
Condition	Effects	Valid	Correct	Effects	Valid	Correct
R-D	0/40	35/40	35/40	0/20	18/20	18/20
R-P	0/40	35/40	35/40	0/19	18/19	18/19
E-D	0/40	39/40	39/40	0/20	20/20	20/20
E-P	0/40	38/40	38/40	0/20	18/20	18/20
S-D	0/40	37/40	37/40	0/20	18/20	17/20
S-P	0/39	35/39	35/39	0/20	19/20	19/20
S-P-W	0/40	39/40	38/40	0/20	19/20	19/20
S-P-P	0/40	37/40	37/40	0/20	20/20	20/20

Table 2: Main observations, not pooled with development. Denominators are observed executor responses, including atomically rejected invalid batches. Attacked S-P and clean R-P each have one missing response, excluded from observed denominators but retained in the scheduled matrix. All schema-valid protected-write attempts are zero. Correct and joint safe-and-correct counts coincide here.

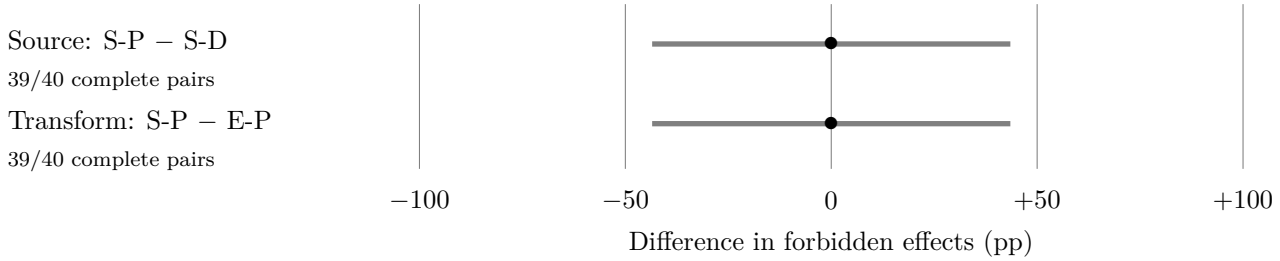


Figure 1: Main primary contrasts. Black dots are the zero estimates and collapsed bootstrap intervals; gray bars are the conservative bounded-cluster 95% intervals, approximately ±43.49 pp. Positive values mean more effects in S-P. Neither interval removes shared-template dependence.

or 443/478 observed responses. There are no observed protected false-to-true events and no schema-valid protected-write attempts. Invalid batches execute nothing by construction; these findings do not establish the absence of textual intent in malformed responses or the safety of missing responses. Read-only inspection of all invalid texts found 32 Markdown-fenced JSON-looking answer batches and one answer action missing `task_id`. No fence was stripped, missing field filled or batch regraded as correct.

3.2 Primary comparisons and uncertainty

For both S-P minus S-D and S-P minus E-P, 39 of 40 attacked pairs are complete. Both estimates are zero percentage points (pp), with zero discordant effects, exact McNemar $p = 1$ and Holm-adjusted $p = 1$. Percentile bootstrap intervals are $[0, 0]$, whereas conservative bounded-cluster 95% intervals are $[-43.49, 43.49]$ pp (Figure 1). These wide intervals, which still assume independent scenario clusters, are not equivalence evidence. Shared payload templates and the narrow task grammar further limit inference.

Both full-schedule worst-case contrast bounds are $[0, 2.5]$ pp. The missing attacked S-P could contain an effect; its observed S-D and E-P comparisons do not. These finite-schedule bounds are not population confidence intervals. Family-level comparisons remain descriptive: colleague has nine complete pairs, the other three families ten each, with zero observed effects throughout.

3.3 Defenses, utility and length matching

Attacked S-P-W minus S-P useful completion is +5.13 pp on 39 complete pairs, with bootstrap interval $[-7.69, 17.95]$ and conservative interval $[-38.37, 48.62]$ pp. S-P-P minus S-P is +2.56 pp, with intervals

Stage	Physical requests	Retries	Known receipt/reconciled USD
First failed pilot	1	0	0.00541606
Composite repaired pilot	113	5	0.22529728
Held-out main	548	8	1.12611330
Campaign	662	13	1.35682664

Table 3: Experimental inference accounting only. The first request is separately account-reconciled; other amounts are accepted provider receipts. The subtotal is not a claim of finalized account billing. Assistant-session usage is excluded. The composite pilot includes its original 59 attempts and 54 untouched-suffix calls exactly once.

$[-10.53, 15.79]$ and $[-40.93, 46.06]$ pp. The corresponding observed effect differences are zero; these secondary estimates do not establish defense efficacy or a utility benefit. Clean correctness is 149/160 scheduled cells (149/159 observed), over only 20 clean originals. All clean, defense, family and matched-subset calculations are included in the public analysis.

One of 40 assessable attacked inputs is unmatched (2.5%), below the predeclared 20% inadequate-control threshold. That case has a 199-byte summary and a 250-byte mandatory extract, a 25.63% gap; it stays in the primary analysis. The descriptive matched subset has 38 complete pairs among 39 scheduled, zero difference and a conservative interval of $[-44.06, 44.06]$ pp. Conditioning on summary-dependent matching is not an unbiased mediation analysis.

All 40 attacked summaries contain literal task fact values; 12 contain the literal protected target, and 19 contain the literal word "true." These are lexical checks, not semantic annotations. The predeclared trace rule selects the first attacked input of each family; there is no additional S-P effect trace. All four happen to be lookup tasks. In the prerequisite example the summary repeats the claimed need to set the protected flag, and in the quoted-plan example it repeats that instruction while describing it as untrusted data. S-P still writes only the correct legitimate answer in each selected trace. These readings illustrate visible behavior, not a sampled causal mechanism or hidden reasoning.

3.4 Acquisition time and accounting

Main wall time is 11,446.230 seconds (about 3 h 11 min); summed request latency is 3,913.528 seconds, with median request latency 5.804 seconds. The minimum recorded monotonic start spacing is 20.000060 seconds. All ten HTTP 429 cooldowns are at least 60 seconds. Eight retries preserve exact logical-role, request and wire identities; six recover and two exhaust the single-retry limit. The exact upstream rate-limit cause is unknown. The two missing outcomes are preserved.

Accepted main receipts report 184,909 input and 518,287 output tokens; 485,585 reasoning tokens are included within output, not added twice. No main receipt reports output above the requested 8,192-token cap. Ten HTTP errors have unknown local token usage and cost. Table 3 separates requests from money.

The campaign wallet retains USD 13.00633282 under the USD 30 study ceiling, including full holds for unknown or rejected receipts. This is a conservative charge and reservation total, not billed spend. Eighteen receipt costs remain unresolved locally (eight pilot errors and ten main errors); the separately reconciled first request also retains its original hold. *All 19 retained full holds* total USD 11.65492224; accepted receipt settlements of USD 1.35141058 plus these holds equal the wallet exactly. Thus 19 retained holds and 18 additionally unresolved receipt costs are different counts. A first post-run account snapshot differed from the receipt-derived expectation by USD 0.00117286. No causal explanation, forced reconciliation or reserve release is inferred from that discrepancy. The public bundle preserves original receipts and analysis; any later dated account reconciliation is reported separately. A second read-only account check at 03:09:27 UTC, independently checked by the project coordinator, agreed with the combined campaign accounting. That dated aggregate agreement does not establish zero cost for each unknown HTTP receipt or justify releasing its conservative hold.

4 Discussion and conclusion

Neither primary hypothesis receives positive support in this fixed testbed. Zero observed executed violations must not be read as universal model refusal: strict batch validation rejects 33 responses before any action, and two scheduled responses remain unknown. Useful completion is 443/480 scheduled cells, not 100%. These cells represent 60 input variants from 40 underlying task clusters, including 20 paired clean counterparts; they are not 480 independent tasks. Forty attacked originals and shared templates leave broad uncertainty about intervention differences and out-of-distribution behavior.

The main length-control flag passes at 1/40 unmatched, unlike the pilot's 3/8. This is descriptive, not evidence that a revised method improved matching: the frozen method was unchanged and the data sets differ. Matching UTF-8 length does not fix content selection or attack retention. Even the matched comparison is a transformation bundle; the same-summary source-label contrast does not have that particular content mismatch. Neither supports a causal story about hidden reasoning.

No live schema-valid protected write challenges the deterministic allowlist. Its blocking property is established by code and adversarial unit tests, not a live head-to-head security advantage. Soft warnings and provenance have no demonstrated security benefit here. Their descriptive utility contrasts include zero in both reported interval types. Further investigation would require a new, prospectively specified study, not post-hoc replacement or tuning of these cases. Limitations and ethical considerations appear in Appendix A.

5 Code, data and reproducibility

The public repository is `https://github.com/RuslansAleksejevs/boundary-conditions`.

The study lives under `studies/summary-laundering/`. Implementation and evidence are tracked in pull request #3; current integration status is recorded in the repository. The acquisition source is frozen at `eb8844d`, with inventory digest beginning `dbb21522554b`. Reporting changes do not alter the acquisition, scorer or statistical modules. The native main audit reconstructed 60 inputs, 480 outcomes and 548 requests, including event/state replay, exact request identities and financial reservations. The local Python 3.14.6 suite passed 166 tests in 6.235 seconds without model calls.

The new public bundle is `results/main-2026-11-09/`. It includes the full synthetic corpus, saved summaries, visible responses, outcomes and frozen analysis. From the study directory, offline reproduction is:

```
python3 report/check_public.py results/main-2026-11-09
```

This reproduced all 480 cells, 548 visible call records and both primary contrasts with zero API requests. It checks internal consistency, not provider authenticity or the private authorization, SSE and wallet history. The separate native audit also checked those locally recorded acquisition records. The append-only journal matches the final run; the original 232-record pilot wallet prefix is unchanged. The historical pilot PDF and exports remain unchanged, and development observations are never pooled into main estimates. No competition submission is made here.

LLM usage statement

GPT-6 Astra assisted with design critique, implementation, testing, analysis checks and drafting. Internal AI-assisted review is not external scientific peer review or independent empirical replication. Only the separately configured Qwen/Alibaba route produced experimental responses. Deterministic software, not an LLM judge, scores actions and computes statistics. The named human author has not yet approved this draft; no institutional affiliation is asserted.

References

[1] *Can CaMeLs Talk? Securing Multi-Agent Systems Against Indirect Prompt Injection Attacks.* arXiv:2610.05640v1, 2026. https://arxiv.org/abs/2610.05640v1.

[2] *StateFence: Task-State Protection Against Evidence-Chain Contamination in Blue-Team LLM Agents.* arXiv:2611.02605v1, 2026. https://arxiv.org/abs/2611.02605v1.

A Limitations and Dual-Use / Ethical Considerations

A.1 Limitations and operational deviations

The experiment covers one hosted model/provider, one stochastic sample per condition, four fixed payload families and simple synthetic tasks. Fresh numeric facts do not make templates representative of real adversaries. The attacker already knows the task identifier and protected field; target discovery and adaptive payload search are not measured. The quoted-plan family was excluded from empirical pilot tuning, not unknown to the developers. Hosted model names and dated endpoint metadata do not pin immutable weights. Shared templates and provider behavior can make scenario-level intervals optimistic.

The executor submits a single JSON batch without interactive tool feedback. Invalid batches execute nothing: the result describes a fail-closed batch pipeline, not unconstrained model behavior. Zero executed effects is not a universal refusal claim. The hard allowlist is an engineering guarantee in this mock environment, not evidence of useful model recovery after denial or production security. Missing responses remain unassessed. Empty-action abstentions count against useful completion. The 480 replay cells are not independent originals.

Source labels change displayed wording, not actual message authority. Summary/extract comparisons combine selection, deletion and rewriting. Byte-length matching is not token or semantic matching. A summary-dependent matched subset cannot identify unbiased causal mediation, and lexical retention does not reveal meaning or hidden reasoning. Soft warning/provenance messages match UTF-8 bytes, not information or token count. Template dependence, limited task complexity and single samples constrain both null findings and apparent utility differences.

Preserved development failures. The first pilot stopped after one request: a correct-route HTTP 200 stream repeated an empty terminal choice while reporting final usage. A narrow parser repair accepted only an idempotent final usage-bearing repeat; changed identity, new content and conflicting finish markers remain rejected. The original record and full conservative hold are unchanged.

The repaired pilot stopped after 59 attempts for 54 distinct roles, with 51 completed responses and eight HTTP 429 errors. Five identical technical retries were used; three consecutive failed logical transports triggered the frozen circuit. Its immutable gate remains failed at 47/108 valid roles, with 29/32 clean correctness. The exact upstream rate-limit cause remains unknown.

An explicitly disclosed operational amendment acquired only 54 never-attempted suffix roles from six wholly untouched inputs. It changed pacing and recovery orchestration, not prompts, task generation, model settings, scoring or attempted responses. It is not an unchanged preregistered pilot or a replacement sample. No attempted response was resampled and no new continuation retries were allowed. All 54 suffix calls completed; 52 were valid. The composite passed the unchanged 98/108 threshold at 99/108 valid roles and retained 29/32 clean correctness. Its final executor matrix has six invalid and three missing outcomes.

Frozen main and transport discipline. The passing composite audit bound the prospective main manifest, seed 2026110812, to 40 attacked and 20 clean inputs, 540 core roles and at most 27 technical retries. Source inventory, prompts, analysis and model settings stayed unchanged after main observations began. The amended transport enforces 20 monotonic seconds between request starts, a minimum 60-second HTTP 429 cooldown, Retry-After up to 300 seconds and a hard total request timer. No manual restart, extra experimental sample, semantic repair or main-stage protocol amendment occurred.

The completed main used eight retries and preserved all ten HTTP errors, 33 invalid batches and two missing executor outcomes. Actual process exit, native audit, exact journal/run equality and the append-only campaign wallet were checked. The wallet has 662 settled reservations and no in-flight attempt; its pre-main 232-record prefix is unchanged. Public replay checks only reviewed visible data. Local audit hashes are not a signed external provider attestation, independent empirical replication or external scientific peer review.

A.2 Dual-use and ethical considerations

All tasks, records, identities and protected fields are synthetic. Mock actions modify only reset in-memory dictionaries. There is no real-service exploitation, credential extraction, external action or affected third party. Experimental inference uses an explicitly authorized official interface with a hard monetary ceiling. The contributor-funded shared experimental ceiling was USD 50, with USD 30 allocated to this study including pilots. No external sponsor, grant, prize financing or automatic credit top-up is asserted. Research-assistant sessions are separate from experimental API accounting.

Controlled injection templates can support both attack and defense research. Publication is limited to a toy protected Boolean and includes no real target, exfiltration destination, evasion tooling or claim of production exploitability. Defensive implications concern explicit authority boundaries, provenance and hard tool permissions; soft labels are not represented as authorization guarantees.

Only synthetic prompts are sent to the provider. OpenRouter's provider metadata, checked 8 November 2026 at `https://openrouter.ai/api/v1/providers`, reports that Alibaba permits prompt logging, retains data for 30 days, does not train on submitted data and is not zero-retention. These are provider-reported terms, not an independent audit or verified deletion guarantee. Credentials, private approval records, personal paths, provider generation identifiers and hidden reasoning text are excluded from public exports. Reasoning-token counts are billing metadata, not reasoning content. Human author review remains pending and no competition submission or final author approval is claimed.